

データセキュリティ

データセキュリティとは

- より広い(?)概念に「情報セキュリティ」がある
- データセキュリティ $\subset$ 情報セキュリティ
 - 「情報」は無形のものも含まれるが, 「データ」の場合は, 電子化されたものに限定して捉えていることも多いようだ
- サイバーセキュリティ $\supset$ 情報セキュリティ
 - 情報セキュリティとほぼ同義と思われるが, インターネットとの関係を強調する文脈で使われることも多いようだ

※ 今日の授業では情報セキュリティについて述べる

1

2

情報セキュリティ

- 情報資産を脅威から守ること

情報資産

情報, データ, コンピュータ等のハードウェア, 記録媒体, など

守る

(情報資産の) 機密性, 完全性, 可用性 (+ 真正性, 責任追跡性, 否認防止, 信頼性) 等の条件 (特性) を維持すること

脅威

情報資産を損ねる可能性のある, 望ましくない, または予想していない事象 (インシデント) の原因となるもの

3

情報資産

- 顧客情報や販売情報など, さまざまな有形無形の情報そのもの
- ファイルや電子メールなどの電子データ
- CD-ROM, USBメモリ, SDカード, 紙などの記録媒体 (メディア)
- データベースシステムやアプリケーションなどのプログラム (ソフトウェア)
- パソコンやサーバ等のコンピュータや設備, 建物等 (ハードウェア)
- 広義には, 製品やサービスを提供する能力, 人材, 営業権, 企業イメージなど, 情報に関係するもの全てが含まれる

4

守るべき特性 (CIA; 情報セキュリティの3要素)

機密性 (Confidentiality)

- 許可された者だけが情報にアクセスできるということ
- ※ 許可の対象は人に限らない。機器やプログラムなども含まれる
- ※ 閲覧・書き換えなど個別に制限する

完全性 (Integrity)

- 情報が正確で欠落がないこと、改竄されたり破壊されたりしていないということ、また、その状態を保つこと

可用性 (Availability)

- 許可された者が必要なときにいつでも情報にアクセスして利用できるということ

5

情報セキュリティの7要素

先の3要素に加えて...

真正性

- 利用者や情報資産が本物である (なりすましや偽物でない) ということ

責任追跡性

- 情報へのアクセスや操作が誰によって行われたかを一意に追跡でき、その責任を明確にできるということ

6

情報セキュリティの7要素

(つづき)

否認防止

- 発生した事象や行為や行為者を、後に否認されないように証明できるということ

信頼性

- データに対する操作が確実に行われ、意図した通りの結果を出すということ

7

インシデント・脅威・脆弱性

インシデント

- 情報資産を損ねる可能性のある、望ましくない、または予期していない**事象**。例えば、情報の毀損・改竄・漏洩、システムの動作不良、設備やサービスの停止など

脅威

- インシデントの原因となるもの。例えば、災害、事故、故障、人為ミス、故意の攻撃など

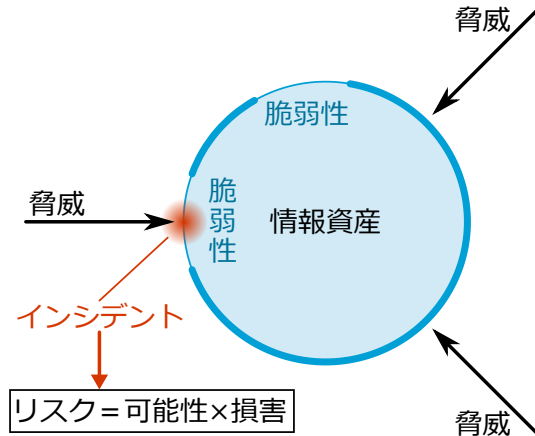
脆弱性

- 脅威に付け込まれる可能性のある、情報資産やその管理体制の**弱点**

8

リスク

- 脅威によって発生するインシデントが情報資産の所有者の目的に対して与える (通常は悪い) **影響**
- インシデントが発生する可能性と発生した場合の結果 (通常は**損害**) で見積もられる



テキスト p.115 図8-2 を元に作成

9

リスクの顕在化

- 情報資産, 脅威, 脆弱性の3つがそろうとリスクが高まる
- 情報資産の価値が下がれば (インシデントの際の損害が少なくなるので) リスクは低下する
- 脅威がなくなったり弱まったり, また, 脆弱性を取り除いたり減らしたりすると, (インシデントの発生する可能性が低まったり, インシデントの際の損害が少なくなったりするので) リスクは低下する

(前スライドの図を参照)

10

セキュリティ対策

1. 識別
守るべき対象 (情報資産), 脅威, 脆弱性をもれなく把握する
2. 評価
発生する可能性のあるインシデントとそのリスク (発生可能性と損害) を特定し, 分析し, 評価 (点数化) する
3. 対応
リスクが受容水準を超えるインシデントについて, リスクの大きい順に対応していく (cf. トリアージ)

11

リスク対応

リスク回避

- リスクを顕在化させる要因そのものを取り除く

リスク移転

- インシデント発生のおそれがあるリスクを第三者に移転する

リスク保有

- リスクを把握した上で, 特に対策せずにその状態を受け入れる

リスク低減

- インシデント発生の可能性を下げる, 発生時の損失を抑える

12

リスク回避

- リスクを顕在化させる要因そのもの (情報資産, 脅威, 脆弱性のいずれか) を取り除く
- 情報資産がもたらす利益が少ないのにリスクが高い場合, あるいは発生時の損害が重大な場合にも行われる

例えば :

- 水害時に浸水のリスクのある地階から上層階へ設備を移転する
- 情報資産そのものを放棄する

など

13

リスク移転

- インシデント発生のおそれがあるリスクを第三者に移転すること
- インシデント発生の可能性が低くても, 発生時の損害が大きい場合には行われることがある

例えば :

- 保険へ加入する
- 業務を外部に委託する

など

14

リスク保有

- リスクを把握した上で, 特に対策をせずにその状態を受け入れる (要は何もしないということ)
- リスクが許容できる (受容水準を超えない) 場合に選ばれる
- インシデント発生時の損失よりもリスク対策にかかるコストの方が大きいなど, 現実的な対策がないために, やむを得ず (リスク保有を) 受け入れざるをえない場合もある

15

リスク低減

- インシデント発生の可能性を下げる, あるいはインシデント発生時の損失を小さくする

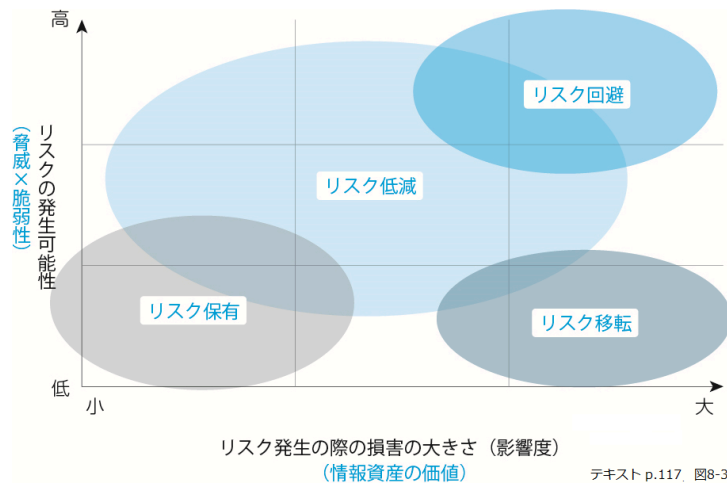
例えば :

- 地震発生に備え, 設備の耐震補強をする
- サーバを多重化する
- データをバックアップする

など

16

リスク対応



17

情報セキュリティの要素技術

- 暗号化
 - 電子署名
 - 個人認証
 - 生体認証
 - 多要素認証
- ※ 電子署名も個人認証に使える

など

18

暗号化

- データの通信, 保存の際の機密性・完全性を守ることができる
 - 盗聴などによって漏洩しても, 復号鍵がない限り内容を読めない
 - 暗号鍵がなければ改竄もできない

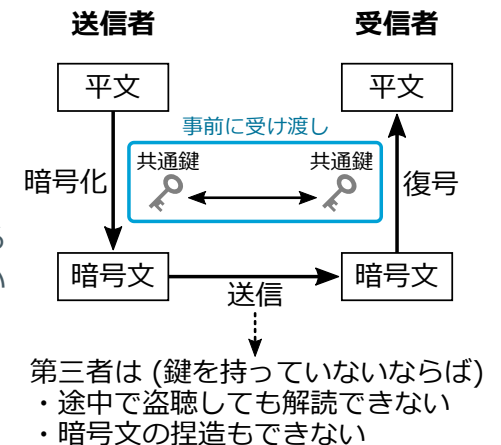
そのしくみ

- 元のデータ (平文; ひらぶん, へいぶん) を暗号鍵で暗号化したデータ (暗号文) を送信したり保存したりする
- 暗号文を平文に戻す (復号) には復号鍵が必要
- 暗号鍵 = 復号鍵の場合, 共通鍵という

19

共通鍵暗号方式

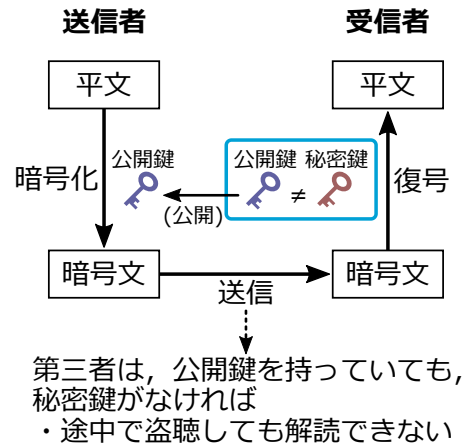
- 暗号鍵と復号鍵が共通 (共通鍵)
- 送信側と受信側で, 共通鍵を事前に安全に受け渡ししておく必要がある (鍵配送問題) ... 困難
 - そもそも安全に送る手段があるなら, 平文もそれで送ればよい
 - 鍵を安全に送るために暗号化するなら, そのための鍵はどうやって送るのか



20

公開鍵暗号方式

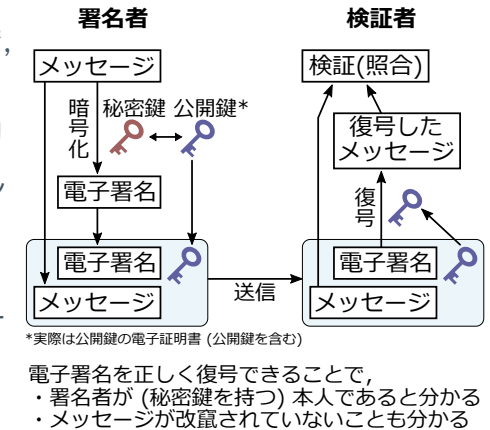
- 公開鍵と秘密鍵のペアからなる
 - 一方の鍵で暗号化したものは、他方の鍵で復号できる
 - 通常は公開鍵で暗号化し、秘密鍵で復号する(逆も可能 → 電子署名(後述))
 - 秘密鍵さえ厳重に秘匿しておけば、第三者に解読される心配はない
- 鍵配送問題は起こらない



21

電子署名

- 署名者の真正性を保証することで、メッセージの完全性を保証する
- 公開鍵暗号を用いる方法が一般的
 - メッセージを秘密鍵で暗号化して電子署名を生成し、公開鍵、メッセージと共に送信
 - 公開鍵で電子署名からメッセージが正しく復元できることで、本人の署名であると確認でき、完全性も保証される



22

公開鍵の電子証明書

- 公開鍵暗号も電子署名も、公開鍵の真正性に依存した方法である
- そのため、送信者や検証者が入手した公開鍵の真正性を保証するしくみが必要である
- 一般的には、その公開鍵が署名者本人のものであるという電子証明書を、公正な第三者である認証局が本人確認の上発行し、その電子証明書で公開鍵の真正性を保証する
 - 電子証明書には公開鍵自体が含まれるので、公開鍵の代わりにその電子証明書を用いることになる
 - 電子証明書の真正性は、認証局の電子署名によって保証される

23

SSL暗号化通信 (Secure Socket Layer; SSL)

- インターネット上で機密性・完全性・通信先の真正性を確保しながら通信するためのプロトコル(通信手順)
- https: で始まる URL の WWW サーバとの通信はこれを使っている
- 共通鍵暗号方式、公開鍵暗号とその証明書を組み合わせている
 - 共通鍵の受け渡しに公開鍵暗号とその証明書をを用いる
 - 共通鍵の受け渡し後は共通鍵暗号方式で通信する

24

個人認証

- 利用者の真正性を担保することで、機密性と可用性を両立させる
 - かつてはパスワード (や暗証番号) が一般的だったが
 - 脆弱でないパスワードは覚えにくい
 - 覚えやすいパスワードは脆弱性が高く破られやすい
 - メモしたり記録したりすると漏洩の危険性があり、管理が面倒
 - 「使いまわし」などの問題もある
- より脆弱性の低い方法が一般的になりつつある:
生体認証, 多要素認証, ワンタイムパスワード など

25

個人情報保護について

- 機密性の高い情報が多く、取り扱いに注意が必要

※ [第4回「データやAIの使われ方」のスライド 3～5](#)
[第13回\(前回\)「データを扱うときの注意点」のスライド 10～13](#)
を、もう一度復習しておこう

27

生体認証・多要素認証

- 生体認証：本人の体や行動の特徴を用いて認証する
指紋認証, 顔認証, 網膜認証, 虹彩認証, 静脈認証 (指, 掌),
音声認証, 耳介認証, 行動認証 (筆跡, タイピングや歩行の癖), ...
- 多要素認証 (**M**ulti-**F**actor **A**uthentication; MFA) :
複数の認証手段を併用する認証方法
 - パスワードに加えて, 携帯電話の SMS や認証アプリを併用する方法 (例: 学内ネットワークの SSPR による認証)
 - 暗証番号とICチップ付きのカードの併用 (例: マイナポータル) など

26

個人としてできること

(以下, 総務省の[国民のためのサイバーセキュリティサイト](#)より)

- [サイバーセキュリティ初心者のための三原則](#)
- [家庭での対策 \(一般利用者向けの対策\)](#)
- [職場等での対策](#)
 - [システムを“利用”する人向けの対策](#)
- [事故・被害事例および対処法](#)
 - [家庭での被害事例および対処法](#)

28

参考

- [国民のためのサイバーセキュリティサイト](#) (総務省; 再掲)
 - [サイバーセキュリティの基礎知識](#)
 - [インターネットを利用したサービス](#)
 - [インターネットに潜む脅威](#)
 - [サイバーセキュリティ関連の法律・ガイドライン](#)
- [情報セキュリティ マネジメントシステム - 用語 \(JIS Q 27000:2019\)](#) (kikakurui.com)
 - 国際標準化機構 (ISO) の文書 ISO/IEC 27000 を基とした日本工業規格 (JIS) の文書